

CAPÍTULO 2 · RESUMO DE ESTUDO

Ameaças, Ataques Cibernéticos e Normas de Segurança

Tipos de ameaças e vetores de ataque, técnicas usadas por invasores, principais normas/frameworks de segurança e as práticas de monitoramento, detecção e resposta a incidentes — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base CERT.br/NIC.br/CGI.br, Souppaya & Scarfone, Mitre, ABNT NBR ISO/IEC 27001/27002/27005/27035, Nist CSF 2.0, CIS Controls, LGPD

1. Ameaças e vetores

2. Técnicas dos invasores

3. Normas e frameworks

4. Monitoramento e resposta

Termos-chave

Revisão rápida

01

Tipos de ameaças e vetores de ataque

Ameaças cibernéticas colocam em risco os princípios da segurança da informação: **confidencialidade, integridade, autenticidade, disponibilidade e não repúdio**. Elas se agrupam em categorias: malwares, phishing, engenharia social, DoS/DDoS, força bruta e exploração de vulnerabilidades.

1.1 Malwares — cinco famílias por objetivo

Propagação automática

Se replicam e se espalham sem depender de arquivos hospedeiros

Acesso e permanência

Garantem acesso contínuo/remoto a sistemas comprometidos

worm

bot

botnet

Worm

Replica-se e opera de forma autônoma, sem hospedeiro; explora serviços de rede ou se espalha por e-mail.

Bot / Botnet

Bot dá controle remoto ao atacante (dispositivo "zumbi"); botnet é a rede de zumbis usada em ataques em larga escala (ex.: DDoS).

backdoor

RAT

rootkit

Backdoor

Serviço criado/modificado que permite o retorno do invasor ao dispositivo.

RAT

Trojan de acesso remoto — parece legítimo, mas dá controle interativo ao invasor.

Rootkit

Esconde a presença de invasores/malwares, mantendo acesso oculto de administrador.

Espionagem (spyware)

Coletam informações do usuário/sistema sem consentimento

keylogger

screenlogger

stalkerware

adware

Keylogger

Captura teclas digitadas (ex.: senhas de banco).

Screenlogger

Registra posição do cursor e capturas de tela — burla teclados virtuais.

Stalkerware

Instalado por alguém próximo para espionar o dono do dispositivo.

Adware

Exibe propagandas indesejadas, coletando dados de navegação.

Enganar o usuário

Usam engenharia social ou disfarces para iludir a vítima

trojan horse

scareware

Trojan horse

Não se replica; camufla intenção maliciosa, muitas vezes instalando outras ferramentas.

Scareware

Assusta o usuário fingindo que o dispositivo está comprometido, induzindo a instalar falso software de segurança.

Impacto direto nos dados

Afetam diretamente disponibilidade ou integridade dos dados

ransomware

vírus

Ransomware

Criptografa dados e exige pagamento (cripto) pela chave. Ex.: WannaCry, que se propaga como worm.

Vírus

Autorreplicante, insere cópias de si em arquivos/programas hospedeiros; depende de interação do usuário (file infectors, boot, macros, scripts).

1.2 – 1.6 Outras ameaças

AMEAÇA	COMO FUNCIONA	PONTO DE ATENÇÃO
Phishing	E-mails/sites falsificados que imitam empresas conhecidas para roubar credenciais e dados bancários.	Baixo custo, alta taxa de sucesso; termo vem de "fishing" + "phreaking" (Rekouché, 2011).
Engenharia social	Táticas psicológicas para induzir a vítima a divulgar informações ou executar ações prejudiciais (ex.: se passar por suporte técnico).	Abusa da credulidade da vítima; frequentemente combinada com malware.
DoS / DDoS	Sobrecarrega servidores/redes (largura de banda, memória, processamento) para negar acesso a usuários legítimos.	DDoS usa vários computadores em sincronia (ex.: botnet Mirai x Dyn DNS, 2016).
Força bruta	Tentativas repetidas e automáticas de adivinhar senhas (ex.: ferramenta Hydra).	Autenticação multifator (MFA) neutraliza a simples descoberta da senha.
Exploração de vulnerabilidades	Aproveita falhas (config. incorreta, bug, falta de atualização) para executar ações não autorizadas.	Vulnerabilidades registradas no CVE (Mitre) e detalhadas no NVD (Nist), com severidade em CVSS.

02

Principais técnicas e ferramentas dos invasores

Sequência típica usada por cibercriminosos (e por profissionais de segurança em testes autorizados) para comprometer um sistema.

01 · varredura

Nmap

Examina a rede em busca de aparelhos conectados, portas acessíveis e serviços em execução — desenha um mapa da infraestrutura.

02 · exploração

**Metasploit / Empire
PowerShell**

Frameworks que oferecem exploits e payloads adaptáveis, usados com permissão em testes de segurança e auditorias.

03 · invasão

Exploit + Payload

O exploit aproveita a vulnerabilidade para acessar o sistema; o payload é o código executado depois, definindo as ações do invasor no shell.

04 · credenciais

Hydra

Realiza ataques de força bruta on-line, testando milhares de combinações de senha por segundo.

03

Normas, frameworks e políticas de segurança

Fornecem instruções claras para gestão de riscos, proteção de dados e cumprimento de obrigações legais.

NORMA / FRAMEWORK	O QUE DEFINE
ISO/IEC 27001	Requisitos para o Sistema de Gestão da Segurança da Informação (SGSI) — o que a empresa precisa fazer para organizar e gerenciar a segurança.

NORMA / FRAMEWORK	O QUE DEFINE
ISO/IEC 27002	Conjunto detalhado de controles aplicáveis (controle de acesso, criptografia, segurança física, resposta a incidentes) — como colocar a 27001 em prática.
ISO/IEC 27005	Orientações para gestão de riscos de segurança da informação, apoiando os requisitos de tratamento de riscos da 27001.
ISO/IEC 27035 (1, 2, 3)	Gestão de incidentes de segurança: princípios e processo (1), diretrizes de planejamento (2), operações de resposta (3).
Nist CSF 2.0	Organiza a gestão de riscos cibernéticos em 5 funções contínuas: identificar, proteger, detectar, responder e recuperar.
Nist SP 800-61	Guia para tratamento de incidentes de segurança computacional (Computer Security Incident Handling Guide).
CIS Controls	Recomendações práticas de segurança cibernética para proteger organizações contra os ataques mais comuns e impactantes.
LGPD (Lei 13.709/2018)	Direitos dos titulares de dados e exigências para coleta, armazenamento, tratamento e compartilhamento de dados pessoais no Brasil.

DE ONDE VEM A POLÍTICA DE SEGURANÇA

A empresa combina normas + frameworks + leis nacionais para criar sua **política de segurança da informação**: um documento acessível a todos os colaboradores, com diretrizes, regras e práticas para gerir, proteger e partilhar informações, e para definir as condutas esperadas.

04

Monitoramento, detecção e resposta a incidentes

Empresas precisam ir além de medidas preventivas: identificar, responder e se recuperar rapidamente de problemas de segurança.

SIEM	Security Information and Event Management — coleta e relaciona logs de segurança de várias fontes (firewalls, servidores, computadores).	
IDS / IPS	Analisa tráfego de rede em busca de padrões de ataques conhecidos. Exemplos:	Snort , Suricata .
Honeypot / Honeynet	Ambientes falsos, propositalmente vulneráveis, para atrair invasores e estudar suas ações com segurança.	
Threat intelligence	Reúne informações sobre ameaças, criminosos, falhas e sinais de invasão. Frameworks/plataformas:	Mitre ATT&CK , Misp , Anomali .

EXEMPLO PRÁTICO (RANSOMWARE)

Durante um ataque de ransomware, o Siem identifica um aumento anormal de atividades de criptografia de arquivos, enquanto um feed de threat intelligence alerta sobre um novo grupo ativo (catalogado no Mitre ATT&CK). Com base nisso, a equipe isola os sistemas afetados, impede a disseminação e mitiga os danos — monitoramento contínuo + inteligência de ameaças + processo estruturado de resposta.



Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

CVE Identificador único (Mitre) para cada vulnerabilidade registrada.	NVD National Vulnerability Database (Nist) — detalhes técnicos, severidade (CVSS) e correção.
MFA Autenticação multifator — camada extra de segurança além da senha.	Exploit Programa que aproveita uma vulnerabilidade para acessar um sistema.
Payload	Zumbi

Código executado após o exploit invadir o sistema; define as ações do invasor.

Dispositivo infectado por um bot, controlado remotamente pelo atacante.

Threat intelligence

Processo de reunir e organizar informações sobre ameaças e criminosos virtuais.

Não repúdio

Princípio da segurança da informação que impede que uma ação seja negada por quem a realizou.



Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

- ☐ Explicar a diferença entre worm, vírus e trojan horse quanto à forma de propagação.
- ☐ Diferenciar backdoor, RAT e rootkit — o que cada um garante ao invasor.
- ☐ Explicar como um ransomware causa impacto e por que o MFA não o impede (ele afeta dados, não credenciais).
- ☐ Distinguir phishing de engenharia social (phishing é uma tática específica dentro da engenharia social).
- ☐ Diferenciar DoS de DDoS e citar o exemplo do ataque à Dyn DNS com a botnet Mirai.
- ☐ Explicar a relação entre CVE, NVD e CVSS.
- ☐ Descrever a sequência típica de um ataque: varredura (Nmap) → exploração (Metasploit) → exploit/payload → força bruta (Hydra).
- ☐ Explicar a diferença entre ISO/IEC 27001 e 27002 (requisitos x controles práticos).
- ☐ Listar as 5 funções do Nist Cybersecurity Framework 2.0.



Diferenciar SIEM, IDS/IPS e honeypot quanto à função de cada um no monitoramento.



Referências do capítulo

ABNT. NBR ISO/IEC 27001:2024, 27002:2022, 27005:2023, 27035-1/2/3. Rio de Janeiro: ABNT.

BRASIL. Lei nº 13.709/2018 (LGPD).

CERT.br; NIC.br; CGI.br. Códigos maliciosos. São Paulo, jul. 2023.

CIS. CIS Critical Security Controls v8.1. 2024.

CICHONSKI, P. et al. Computer Security Incident Handling Guide. Nist SP 800-61 rev. 2, 2012.

KISSEL, R. (ed.). Glossary of key information security terms. Nist IR 7298 rev. 2, 2013.

Mitre ATT&CK. Enterprise matrix; Threat intelligence program (M1019). 2019/2025.

Nist. National Vulnerability Database; Cybersecurity Framework (CSF) 2.0. 2024.

SOUPPAYA, M.; SCARFONE, K. Guide to malware incident prevention and handling, 2013.

REKOUACHE, K. Early phishing. 2011.

Resumo gerado a partir do capítulo "Ameaças, ataques cibernéticos e normas de segurança" (SEG_AUD_SIS_02_ACE_2025) para revisão de prova.